CONFIDENTIAL SECURITY DOCUMENT

Linux Privilege Escalation Assessment

Example Fleet — Shared Server Fleet

[FILL: host1 • host2 • host3 • ...]

Assessment Type	Authenticated Internal Local Privilege Escalation
Foothold Identity	[FILL: e.g. unprivileged LDAP user, identical across all hosts]
Assessment Period	[FILL: start] – [FILL: end]
Report Date	1 January 2030
Hosts in Scope	[FILL: N hosts]
Overall Risk Rating	CRITICAL
Classification	**Confidential — Restricted Distribution**

Distribution: This document contains sensitive security information — including any live compromise evidence, credential-exposure locations, and indicators of compromise — and must not be shared outside the personnel responsible for remediating the identified findings.

Disclaimer: Testing was conducted under written authorisation on infrastructure owned and operated by the client. [FILL: State how much was live-exploited vs. only mapped analytically, e.g. "live exploitation was limited to proof-of-concept confirmation on a subset of hosts; other findings are mapped analytically and marked Not Tested."]

Table of Contents

1 Executive Summary **2**
1.1 Overview . . . 2
1.2 Overall Risk Rating . . . 2
1.3 Findings by Severity . . . 2
1.4 Confirmed vs. Mapped . . . 2

2 Scope & Methodology **3**
2.1 Subject & Scope . . . 3
2.2 Approach . . . 3
2.3 Status Definitions . . . 3

3 Host Inventory & Facts Sheet **4**
3.1 Fleet at a Glance . . . 4
3.2 The Foothold Identity . . . 4
3.3 Risk Tiers . . . 4

4 Statistics & Risk Posture **5**
4.1 Candidate Disposition . . . 5
4.2 Risk Overview by Category . . . 5

5 Systemic Root Causes **6**
5.1 R1 — [FILL: e.g. Uneven Patch Cadence Across the Fleet] . . . 6
5.2 R2 — [FILL: e.g. Flat Trust Domain (Shared Identity + Shared Storage)] 6

6 Exploitation Playbooks **7**
6.1 [FILL: e.g. PwnKit-style SUID/polkit LPE] . . . 7

7 Headline Findings **8**
7.1 F-01 — [FILL: Short, specific finding title, e.g. "PwnKit: pkexec Local Privilege Escalation (CVE-2021-4034)"] . . . 8
7.1.1 Description . . . 8
7.1.2 Technical Details . . . 8
7.1.3 Impact . . . 9

8 Per-Host Candidate Catalog **10**
8.1 [FILL: hostname] — [FILL: Distro/version] ([FILL: n] candidates: [FILL: n]C / [FILL: n]H / [FILL: n]M / [FILL: n]L / [FILL: n]I) . . . 10

9 Loot & Files Worth Checking **11**
9.1 Credentials & Passwords . . . 11
9.2 Private Keys & Certificates . . . 11
9.3 Notable Services & Configs to Review . . . 11

10 Recommendations **12**

11 Appendix A — Tools Used **13**

12 Appendix B — Full Candidate Dataset 13

1 Executive Summary

Overview

An authenticated internal assessment was conducted across [FILL: N] representative hosts in Example Fleet, using the same low-privilege foothold identity on every machine, to determine what a compromised (or malicious) unprivileged account could achieve. [FILL: One sentence on the overall outcome, e.g. "root was obtained on multiple hosts within minutes using public, unweaponised exploits."]

CRITICAL — Key Takeaway

Result — [FILL: one-line verdict].

Headline conclusions:

- [FILL: Headline finding 1, e.g. "root confirmed on N hosts via public LPE exploits"]
- [FILL: Headline finding 2, e.g. "shared identity + shared NFS home directories mean a credential harvested on one host works on all of them"]
- [FILL: Headline finding 3]

Overall Risk Rating

CRITICAL

Findings by Severity

Severity	Count	Meaning
CRITICAL	[FILL: n]	CONFIRMED root on at least one host
HIGH	[FILL: n]	[FILL: Meaning for this engagement]
MEDIUM	[FILL: n]	[FILL: Meaning for this engagement]
LOW / INFO	[FILL: n]	Hygiene / defence-in-depth gaps

Confirmed vs. Mapped

Status	Count	Meaning
CONFIRMED	[FILL: n]	Exploited live during the engagement
MAPPED (NOT TESTED)	[FILL: n]	Identified and assessed applicable, not exploited (client-approved scope limit)

2 Scope & Methodology

Subject & Scope

Item	Detail
Fleet	Example Fleet
Hosts in scope	[FILL: N hosts - list or reference the host inventory]
Foothold	[FILL: e.g. one shared unprivileged LDAP identity, no elevated group membership]
Assessment type	Authenticated internal local-privilege-escalation review

Approach

1. **Enumeration.** [FILL: e.g. an automated enumeration tool (linPEAS or similar) was run from the unprivileged foothold on each host.]
2. **Candidate triage.** Every candidate vector the tool surfaced was individually assessed for applicability against the host's actual patch level and configuration, rather than trusted at face value.
3. **Adversarial verification.** [FILL: Describe how candidates were confirmed or rejected - e.g. cross-checked against distro changelogs / backport status before being marked Confirmed, Version-in-range-unverified, or Not-applicable.]
4. **Selective live exploitation.** [FILL: Describe how many / which hosts had live PoC exploitation, vs. analytical mapping only, and why.]

Verifier note. [FILL: e.g. "Automated tooling flags many CVEs by version range alone; most were rejected as patched distribution backports after manual verification. Do not read a registry match as an exploitable bug without a runtime check."]

Status Definitions

Status	Definition
CONFIRMED	Exploited live against the target host during the engagement.
MAPPED (NOT TESTED)	Assessed applicable but not exploited (scope limit / client request).

3 Host Inventory & Facts Sheet

Fleet at a Glance

[FILL: One paragraph summarising the fleet: how many hosts, what OS/age spread, and what that spread implies about risk.]

Host	Distro	Kernel (build date)	sudo	gcc	Notable
[FILL: host1]	[FILL: distro]	[FILL: kernel (date)]	[FILL: ver]	[FILL: ver]	[FILL: notable config]
[FILL: host2]	[FILL: distro]	[FILL: kernel (date)]	[FILL: ver]	[FILL: ver]	[FILL: notable config]

The Foothold Identity

Every host was assessed from the same account. Its lack of privilege is what makes the results significant — nothing below required any special group or sudo right.

Attribute	Value (identical on all hosts)
User	[FILL: username]
Privileged groups	[FILL: None (no sudo, wheel, admin, docker, lxd, disk, adm, shadow, staff)]
`sudo -l`	[FILL: No output on any host - no cached credential, no sudoers entry]
Container?	[FILL: No - direct host access on every machine]

Why one identity across the whole fleet matters

[FILL: Explain the shared-identity / shared-storage implication: a credential or key harvested on one host is likely to work on the others, so the fleet behaves as one trust domain rather than independently defended machines.]

Risk Tiers

Tier	Characterisation
Legacy — immediate emergency	[FILL: Old/EOL hosts, trivially rootable with public exploits.]
Modern — exposed on the margins	[FILL: Well-patched hosts still exposed to a small number of recent CVEs or structural weaknesses.]

4 Statistics & Risk Posture

Candidate Disposition

Disposition	Count	Meaning
Confirmed	[FILL: n]	Exploited live
Version-in-range-unverified	[FILL: n]	Tool flagged it; not runtime-confirmed
Needs-runtime-check	[FILL: n]	Requires a check not performed in this pass
Not-applicable	[FILL: n]	Rejected after verification (e.g. patched backport)

Risk Overview by Category

Category	Exploitability	Impact	Primary consequence
[FILL: e.g. SUID/polkit]	[FILL: Trivial]	[FILL: Critical]	[FILL: Local root via a public exploit]
[FILL: e.g. NFS misconfiguration]	[FILL: Trivial]	[FILL: High]	[FILL: Cross-host file tampering as root]

5 Systemic Root Causes

[FILL: One paragraph: the small number of structural decisions that generate most of the per-host findings - e.g. uneven patch cadence, a shared identity/storage domain, or default package configurations left unhardened.]

R1 — [FILL: e.g. Uneven Patch Cadence Across the Fleet]

[FILL: Describe the pattern and why it recurs across hosts.]

R2 — [FILL: e.g. Flat Trust Domain (Shared Identity + Shared Storage)]

[FILL: Describe the second systemic root cause.]

6 Exploitation Playbooks

One playbook per confirmed vector. PoCs are for authorised testing only.

[FILL: e.g. PwnKit-style SUID/polkit LPE]

Status: CONFIRMED **Host(s):** [FILL: host1]

Description. [FILL: One or two sentences on the precondition and the bug class.]

[FILL: Confirmed via <tool/exploit name>]

```
illustrative command only -- replace with your own, no real hostnames/output
```

Impact. [FILL: What root access on this host enables.]

Remediation

- [FILL: Patch to the fixed version.]
- [FILL: Interim mitigation if patching must wait.]

7 Headline Findings

ID	Title	Severity	Status
F-01	[FILL: Title]	CRITICAL	CONFIRMED
F-02	[FILL: Title]	HIGH	MAPPED (NOT TESTED)

F-01 — [FILL: Short, specific finding title, e.g. "PwnKit: pkexec Local Privilege Escalation (CVE-2021-4034)"]

Finding Metadata			
ID	F-01	**Severity**	CRITICAL
Affected Host	[FILL: hostname]	**Status**	CONFIRMED
CVE / CVSS	[FILL: CVE-YYYY-NNNNN] / [FILL: n.n]	**Exploitability**	[FILL: Trivial]
Category	[FILL: e.g. SUID / polkit]	**Applicability**	[FILL: Confirmed-applicable]

Description

[FILL: Describe the vulnerable component, the precondition that makes it exploitable on this host (version, config), and why it is one of the most reliable local-root primitives of its kind if applicable.]

Technical Details

Evidence	Detail
[FILL: e.g. SUID binary]	[FILL: -rwsr-xr-x 1 root root ... /usr/bin/pkexec]
[FILL: e.g. Version]	[FILL: package version, release date, pre-fix]

[FILL: Confirmed via <tool/module name>]

```
illustrative command / expected output only -- replace with your own
```

Public exploits. [FILL: Name the public PoC(s)/module used, e.g. an Exploit-DB ID or a named GitHub PoC repository - no need to embed exploit source in the report.]

Impact

CRITICAL — Key Takeaway

[FILL: What full root/administrative access on this host enables, and how it chains with other findings (e.g. shared storage, shared credentials) to affect the rest of the fleet.]

Remediation

- **Patch immediately:** [FILL: package/version to upgrade to.]
- **Interim mitigation** if patching must wait: [FILL: e.g. remove the SUID bit.]
- **Strategic:** [FILL: e.g. plan migration off an end-of-life OS.]

8 Per-Host Candidate Catalog

This section is the exhaustive record: every candidate vector enumerated per host, including those assessed *Not-applicable* (retained with their reason, so nothing looks skipped). Severity is shown as CRITICAL / HIGH / MEDIUM / LOW / INFO in the leading column (C/H/M/L/I).

> **Verifier note.** [FILL: e.g. "Automated tooling matches many classic CVEs by version range alone; almost all were rejected as patched distribution backports after manual verification. Do not read a registry match as an exploitable bug without a runtime check."]

[FILL: hostname] — [FILL: Distro/version] ([FILL: n] candidates: [FILL: n] C / [FILL: n] H / [FILL: n] M / [FILL: n] L / [FILL: n] I)

Sev	Category	Title	CVE	Applicability
C	[FILL: category]	[FILL: Title (F-01)]	[FILL: CVE-YYYY-NNNNN]	[FILL: Confirmed]
H	[FILL: category]	[FILL: Title]	[FILL: --]	[FILL: Version-in-range-unverified]
M	[FILL: category]	[FILL: Title]	[FILL: --]	[FILL: Needs-runtime-check]
L	[FILL: category]	[FILL: Title]	[FILL: CVE-YYYY-NNNNN]	[FILL: Not-applicable (patched)]
I	[FILL: category]	[FILL: Title]	[FILL: --]	[FILL: Not-applicable]

9 Loot & Files Worth Checking

Beyond the privilege-escalation vectors, note anything found that enables lateral movement or is itself an exposure. Report by *path and reason*, not by content.

Credentials & Passwords

Host	Path	Why / next action
[FILL: host]	[FILL: path/to/config]	[FILL: e.g. hardcoded secret - reuse-check against related systems (F-NN)]
[FILL: host]	[FILL: path]	[FILL: why]

Private Keys & Certificates

Host	Path	Why
[FILL: all]	~/.ssh/	[FILL: Reusable keys - pivot risk if identity is shared across hosts]

Notable Services & Configs to Review

- [FILL: host]: [FILL: service/config worth a closer look]

Scope note. [FILL: State any exclusions - e.g. files inside the assessing user's own home directory, or artifacts placed by the assessment team itself, are excluded from this catalog.]

10 Recommendations

Priority	Recommendation
Immediate	[FILL: e.g. Patch or decommission the legacy/EOL hosts with confirmed root.]
Short-term	[FILL: e.g. Establish a regular patch cadence across the fleet; segment the shared trust domain.]
Long-term	[FILL: e.g. Per-host or per-tier credentials instead of one identity everywhere; centralised vulnerability management.]

11 Appendix A — Tools Used

- [FILL: e.g. linPEAS]
- [FILL: e.g. Metasploit]

12 Appendix B — Full Candidate Dataset

[FILL: If the per-host catalog above is a summary, note here where the full machine-readable dataset (CSV/JSON) can be found, or paste a link/path.]

This report is **CONFIDENTIAL** — Restricted to authorised personnel only
Example Fleet — Privilege-Escalation Assessment — 1 January 2030